



Reducing the Attack Surface

Lecture 6

Topics

- ▶ Network Configuration
 - ▶ Ports and Protocols
 - ▶ Firewall Requirements
 - ▶ Other Considerations
- ▶ Ensuring that Unsafe Features are Disabled
 - ▶ Configuring the Surface Area Manually
 - ▶ Managing Features with Policy-Based Management



Network Configuration

- ▶ The following sections will provide an overview of ports and protocols, before diving into considerations for firewall configuration.



Understanding Ports and Protocols

- ▶ Information is exchanged in various methods and formats using protocols.
- ▶ SQL Server listens on
 - a) shared memory – used when client is same server as db instance. Should be rarely used in troubleshooting scenarios.
 - b) named pipes – designed for LAN but may have performance issues with WAN. Supports Kerberos due to changing format of SPNs.
 - c) TCP IP – protocol of choice with security features and network routing standards.



Understanding Ports and Protocols

Static vs Dynamic Ports

- ▶ A port is a communication endpoint in OS used by transport layer protocols
- ▶ SQL Server uses TDP and UDP.
- ▶ Static ports are always constant and predefined.
- ▶ Dynamic ports change each time the service starts. They have to request a port number from OS not used by another service. Windows range: 49152-65535.
- ▶ IANA coordinates internet protocol resources like IP address, domain name, protocol parameters and port numbers of network services. See: <https://www.iana.org/>
- ▶ TCP and UDP use 1433 and 1434.

Figure 9-1 SQL Server protocols

Figure 9-2 Configuring named pipes

Understanding Ports and Protocols

Configuring Ports

- ▶ See allowed protocols in SQL server configuration manager.
- ▶ Protocols for [Instance Name] will show list of protocols as in Figure 9-1

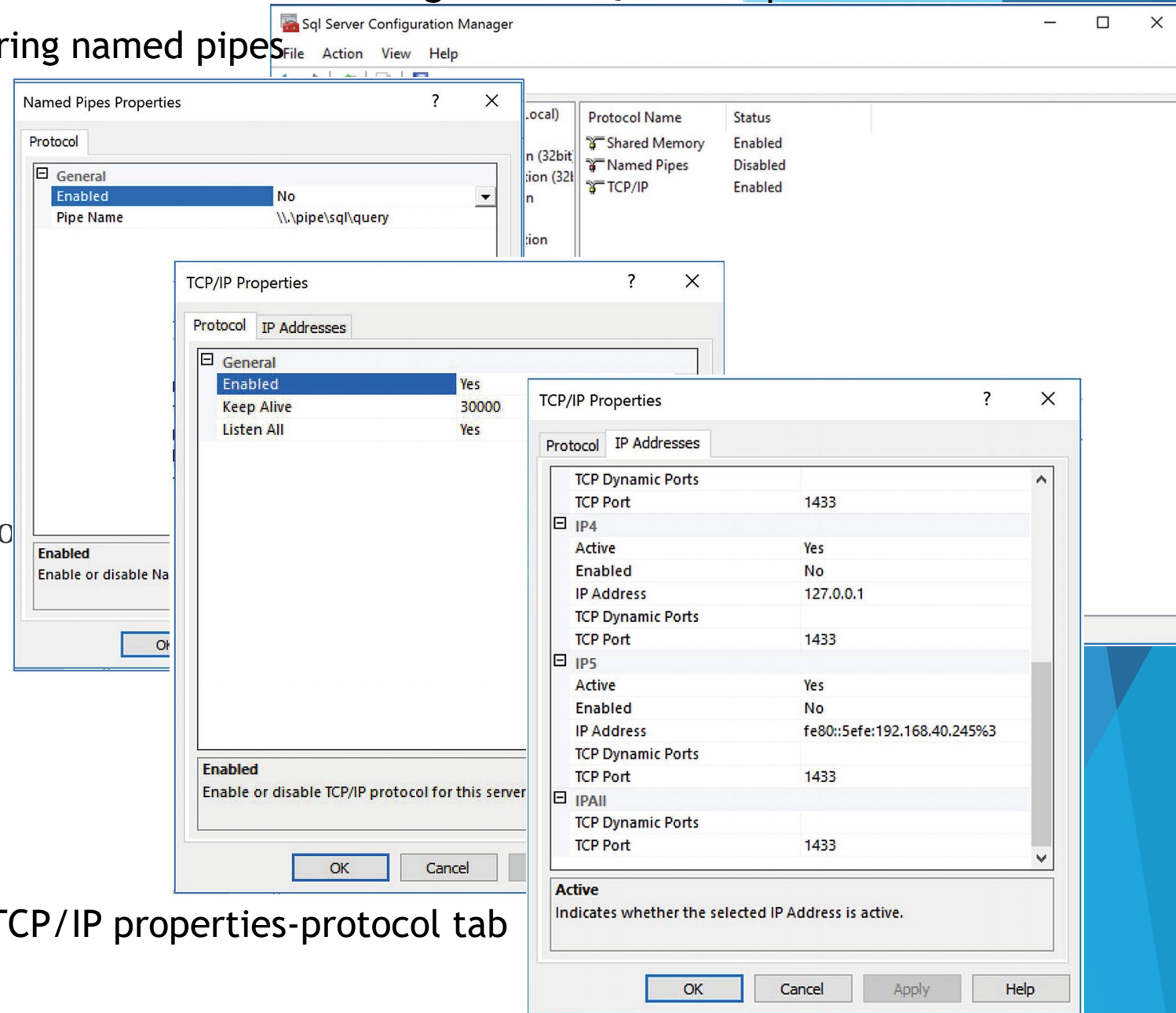


Figure 9-3 TCP/IP properties-protocol tab

Figure 9-4 IP Addresses tab

Understanding Ports and Protocols

Firewall Requirements

- ▶ Used to block network traffic to specific ports
- ▶ Ports can be opened for inbound/outbound/bi-directional traffic
- ▶ In corporate environment, traffic travels through several firewalls as in Figure 9-5.
- ▶ Use Windows Firewall to secure SQL Server.

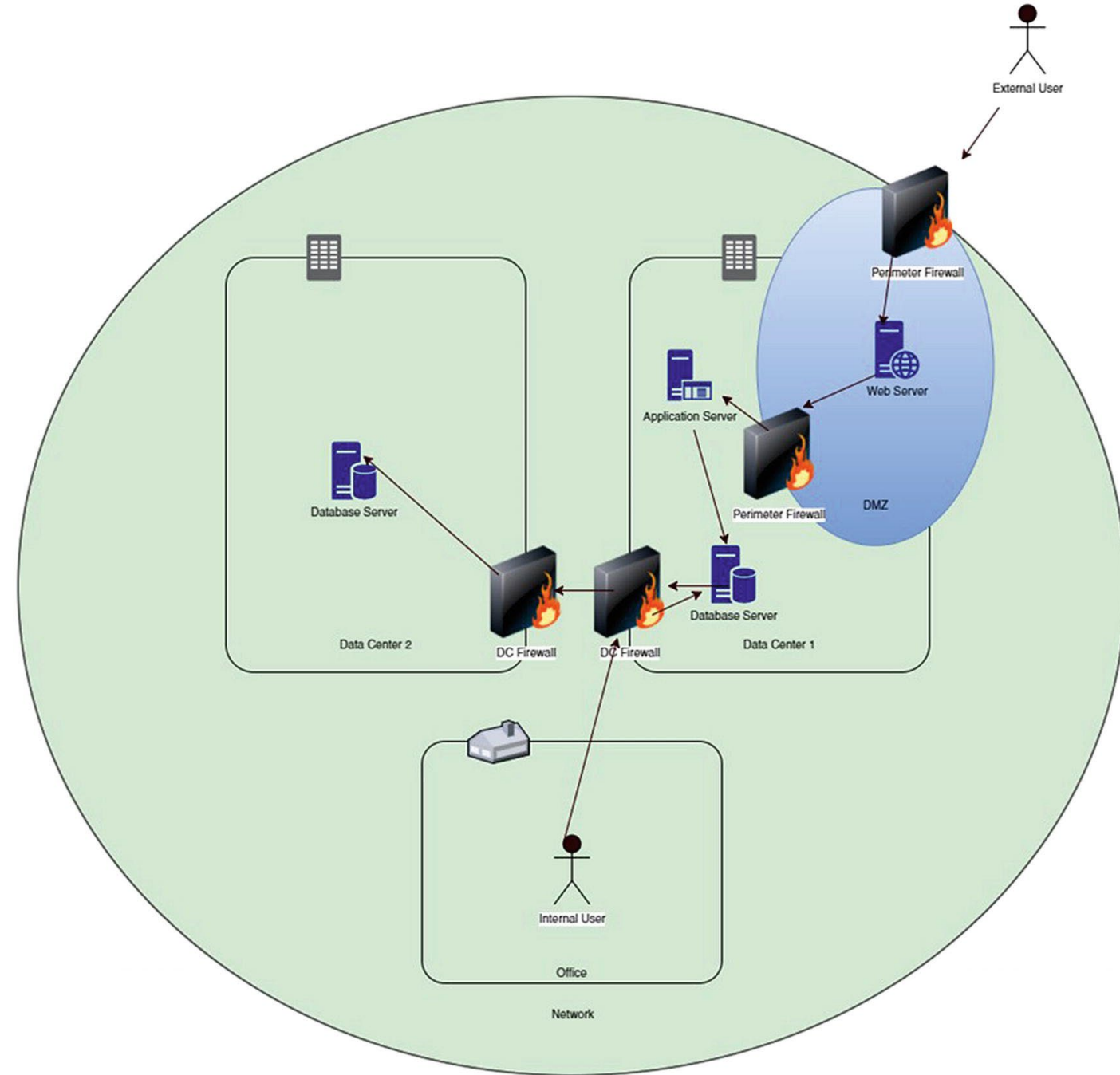


Figure 9-5 Typical firewall topology

Understanding Ports and Protocols

How Clients Communicate With SQL Server

- ▶ Clients communicate using TCP/IP directly with a named instance, using a connection string or the instance name through SQL Browser resolution.
- ▶ Figure 9-6 illustrates the decision tree during client communication with instance.
- ▶ Named pipes will always use Port 445, also used by file and printer sharing. Disable if not used.

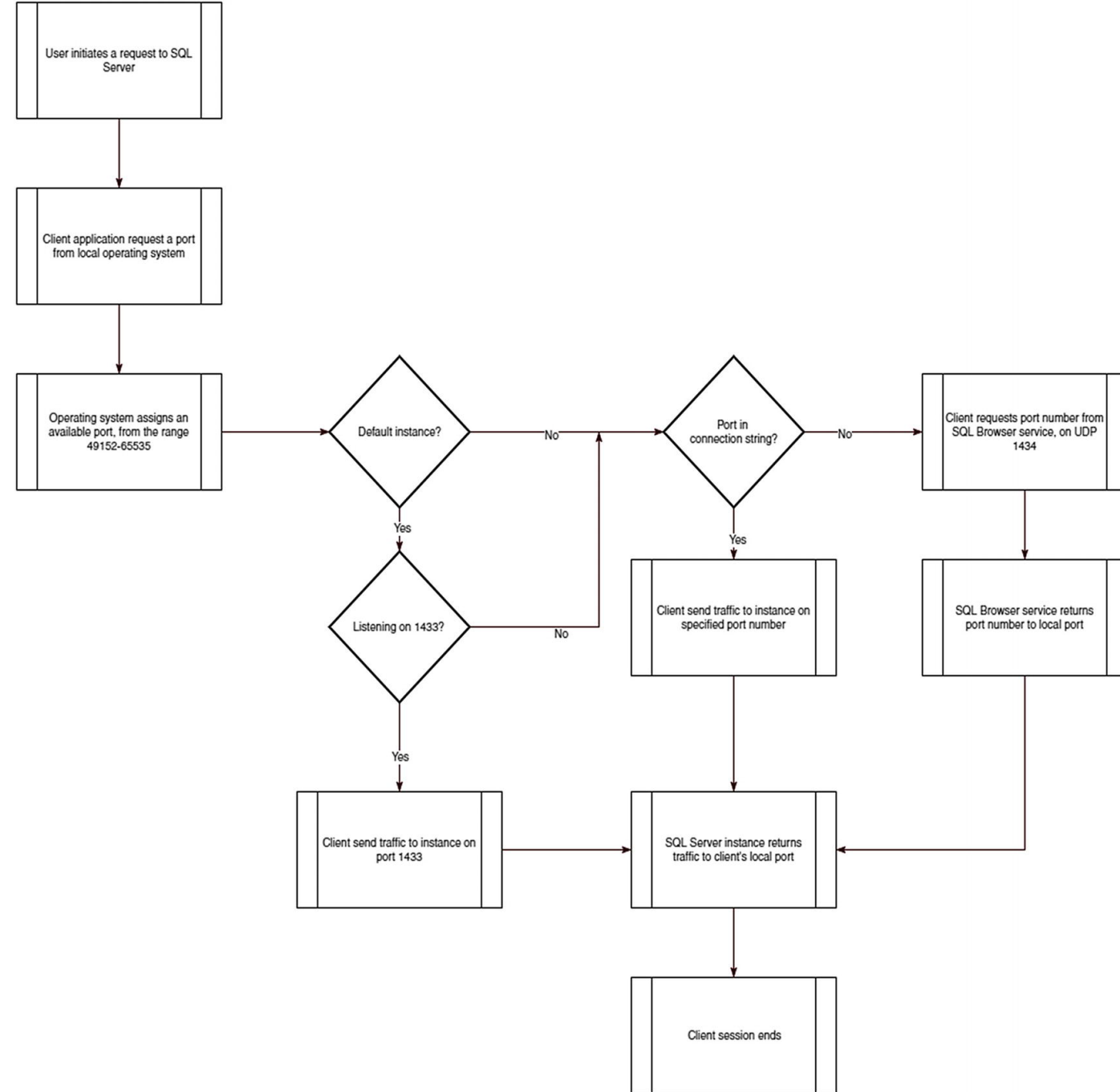


Figure 9-6 Communication process



Understanding Ports and Protocols

Ports Required by SQL Server

- ▶ SQL Server ports are detailed in Table 9-1.
- ▶ Open only ports that are required.

Table 9-1 Ports Required by SQL Server

Feature/Component	Port Requirements
Default instance	TCP 1433 (This can be changed by a DBA.)
Named instance	Dynamic port (This can be changed by a DBA.)
DAC (Dedicated Administrator Connection) on default instance	TCP 1434
DAC on named instance	Dynamic port
SQL Browser service	UDP 1434
Instance running over HTTP endpoint	TCP 80 (This can be changed by an IIS administrator.)
Instance running over HTTPS endpoint	TCP 443 (This can be changed by an IIS administrator.)
Service Broker	No default port, but 4022 is used as standard
Database Mirroring	No default port, but 7022 is used as standard. If there are multiple instances with Database Mirroring endpoints on the same server, then the port number is often incremented with + 1.
AlwaysOn Availability Groups	No default port, but 7022 is used as standard. If there are multiple instances with Database Mirroring endpoints on the same server, then the port number is often incremented with + 1. (Availability Groups use the Database Mirroring endpoint.)
Replication - Instance connections	Connections to the instance use the port configured for the instance.
Replication - Web sync	TCP 80 (This can be changed by an IIS administrator and DBA.)
Replication FTP	TCP 21 (This can be changed by a DBA.)
Replication - File sharing	UDP 137, UDP 138, TCP 139. (TCP 445 is also required if NetBIOS is used.)
T-SQL Debugger	TCP 135
Analysis Services	TCP 2382 (This can be changed by a DBA.)
SQL Browser Service (when used with Analysis Services named instances)	TCP 2382
Analysis Services over HTTP	TCP 80 (This can be changed by an IIS Administrator.)
Analysis Services PivotTable service over HTTP	TCP 80 (This can be changed by an IIS Administrator.)
Analysis Services over HTTPS	TCP 443 (This can be changed by an IIS Administrator.)
Analysis Services PivotTable service over HTTPS	TCP 443 (This can be changed by an IIS Administrator.)
Reporting Services Web Service through HTTP	TCP 80 (This can be changed by an IIS Administrator.)
Reporting Services Web Service through HTTPS	TCP 443 (This can be changed by an IIS Administrator.)
Integration Services Runtime	TCP 135
WMI (Windows Management Instrumentation)	TCP 135
MSDTC (Microsoft Distributed Transaction Coordinator)	TCP 135
IPSec (Can be used to encrypt server to server communications)	UDP 500 and UDP 5000



Miscellaneous Considerations

- ▶ Disable file and printer sharing
- ▶ Consider configuration security policies and user rights assignments
- ▶ Virus scans and malware checks should be run frequently.
- ▶ Virus definitions should be up to date.
- ▶ Use patching schedules.
- ▶ Consider which features of SQL Server are absolutely necessary
- ▶ Check log files for suspicious cases.



Ensuring that Unsafe Features Remain Disabled

- ▶ Although SQL Server disables unsafe features by default, these features can be enabled and disabled via SSMS.
- ▶ This section shows how to configure the surface manually as well as using Policy Based Management

Ensuring that Unsafe Features Remain Disabled

Configuring the Surface Area Manually

- ▶ Select Facets under Object Explorer to see the Surface Area Configuration.
- ▶ Figure 9-7 shows the current status of each feature.
- ▶ In this case, CLR integration is enabled as is xp_cmdshell.
- ▶ Use the drop-down box to change the status.

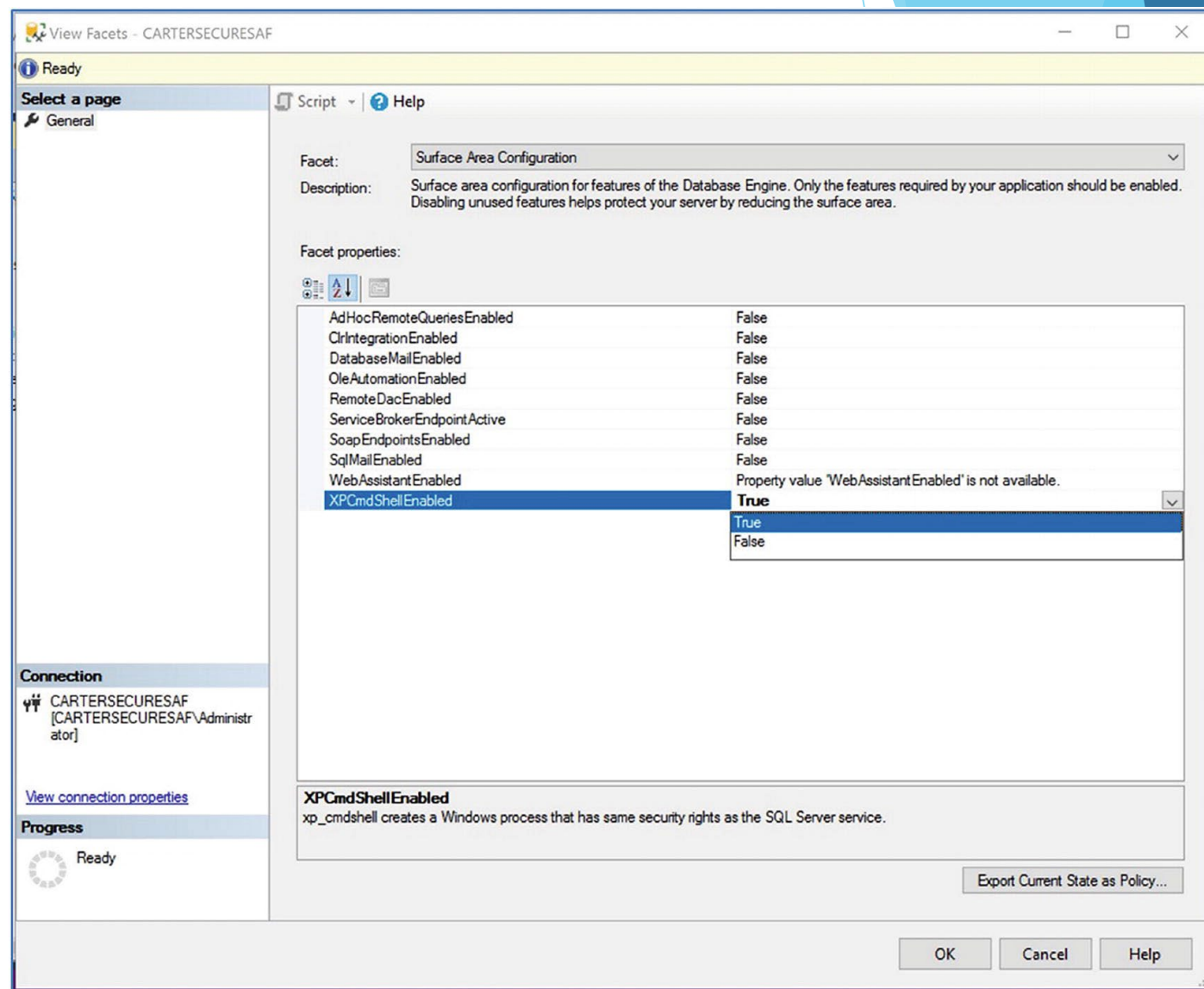


Figure 9-7 Surface Area Configuration facet



Ensuring that Unsafe Features Remain Disabled

Managing Features With Policy-Based Management

- ▶ manual configuration may be impossible for large enterprises. PBM is advisable.
- ▶ Consists of targets, facets, conditions and policies
 - 1) Facets
 - ▶ Collection of policies related to a target
 - ▶ 96 facets in total for SQL Server 2017, but of interest would be `ISurfaceAreaConfigurationForAnalysisServer`, `ISurfaceAreaConfigurationForReportingServices`, and `ISurfaceAreaFacet`
 - 2) Conditions
 - ▶ Boolean expression evaluated against an object property to determine if match specified value.
 - ▶ Each facet has multiple properties to create conditions for
 - ▶ Operators include `=`, `!=`, `LIKE`, `NOT LIKE`, `IN`, `NOT IN`
 - 3) Targets
 - ▶ Entity to apply policy on
 - ▶ Any object in an instance, including Table, database or instance itself
 - ▶ Can use conditions to limit targets for a policy



Ensuring that Unsafe Features Remain Disabled

4) Policies

- ▶ Contains one condition and binds it to one or more targets
- ▶ Specifies an evaluation mode
- ▶ Depending on the evaluation, it may contain a schedule:
 1. On Demand - evaluated when a DBA manually evaluates them
 2. On Schedule - create a schedule at the point when policy is created and evaluated periodically
 3. On Change:Log Only - whenever the relevant property target changes, the policy is evaluated. If change violates policy, error is written in log.
 4. On Change: Prevent - When a property is changed, policy is evaluated and error message thrown if violation exist with the violating statement returned and rolled back.
- ▶ Policies work based on DDL events being fired, so depending on the properties within the facet, not all evaluation modes can be implemented for all facets. Table 9-2 specifies the evaluation modes for each surface area configuration facet.
- ▶ PBM also helps implementing security in other ways, such as preventing stored procedures from being created and modified with certain keywords



Ensuring that Unsafe Features Remain Disabled

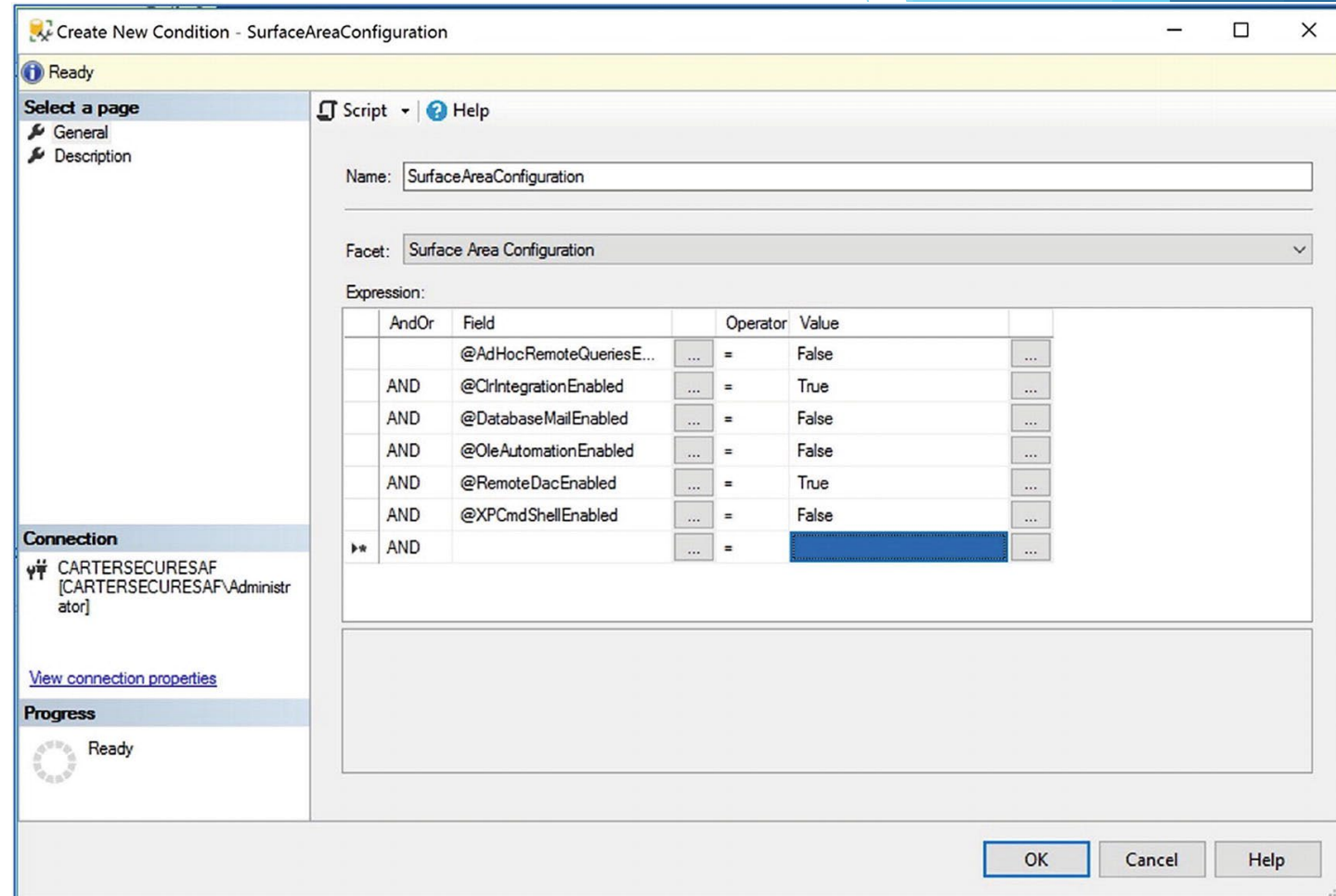
Facet	On Demand	On Schedule	On Change: Log Only	On Change: Prevent
ISurfaceAreaFacet	YES	YES	YES	NO
ISurfaceAreaConfigurationForAnalysisServer	YES	NO	NO	NO
ISurfaceAreaConfigurationForReportingServices	YES	NO	NO	NO

Table 9-2 Evaluation Modes Supported by Surface Area Configuration Facets

Ensuring that Unsafe Features Remain Disabled

Creating a Policy for Surface Area Configuration

- ▶ To do this, create a condition and a policy
- ▶ Drill to Management->PolicyBased Management in Object Explorer and select New Condition in the Conditions node. Figure 9-8 shows this dialog box.
- ▶ Specify a name for the condition and select the Surface Area Configuration facet from the Facet drop down box.
- ▶ In SSMS, the friendly name of the face is returned, not the system name.
- ▶ In the Expression area, properties to include in the condition is selected using drop-down boxes in the Field column.



Create New Condition - SurfaceAreaConfiguration

Ready

Select a page

- General
- Description

Script | Help

Name: SurfaceAreaConfiguration

Facet: Surface Area Configuration

Expression:

	AndOr	Field	Operator	Value
		@AdHocRemoteQueriesE...	=	False
AND		@ClrIntegrationEnabled	=	True
AND		@DatabaseMailEnabled	=	False
AND		@OleAutomationEnabled	=	False
AND		@RemoteDacEnabled	=	True
AND		@XPcmdShellEnabled	=	False
AND			=	

Connection

CARTERSECURESAP [CARTERSECURESAP\Administrator]

[View connection properties](#)

Progress

Ready

OK Cancel Help

Figure 9-8 Create New Condition dialog box

Ensuring that Unsafe Features Remain Disabled

Creating a Policy for Surface Area Configuration (Cont)

- ▶ Next, create the policy by drilling through Management->Policy Based Management in Object Explorer.
- ▶ Select New Policy and invoke Figure 9-9.
- ▶ Specify name for policy and condition to evaluate in the Check condition dropdown list.
- ▶ Select On Demand as evaluation mode - only evaluated when DBA evaluates.

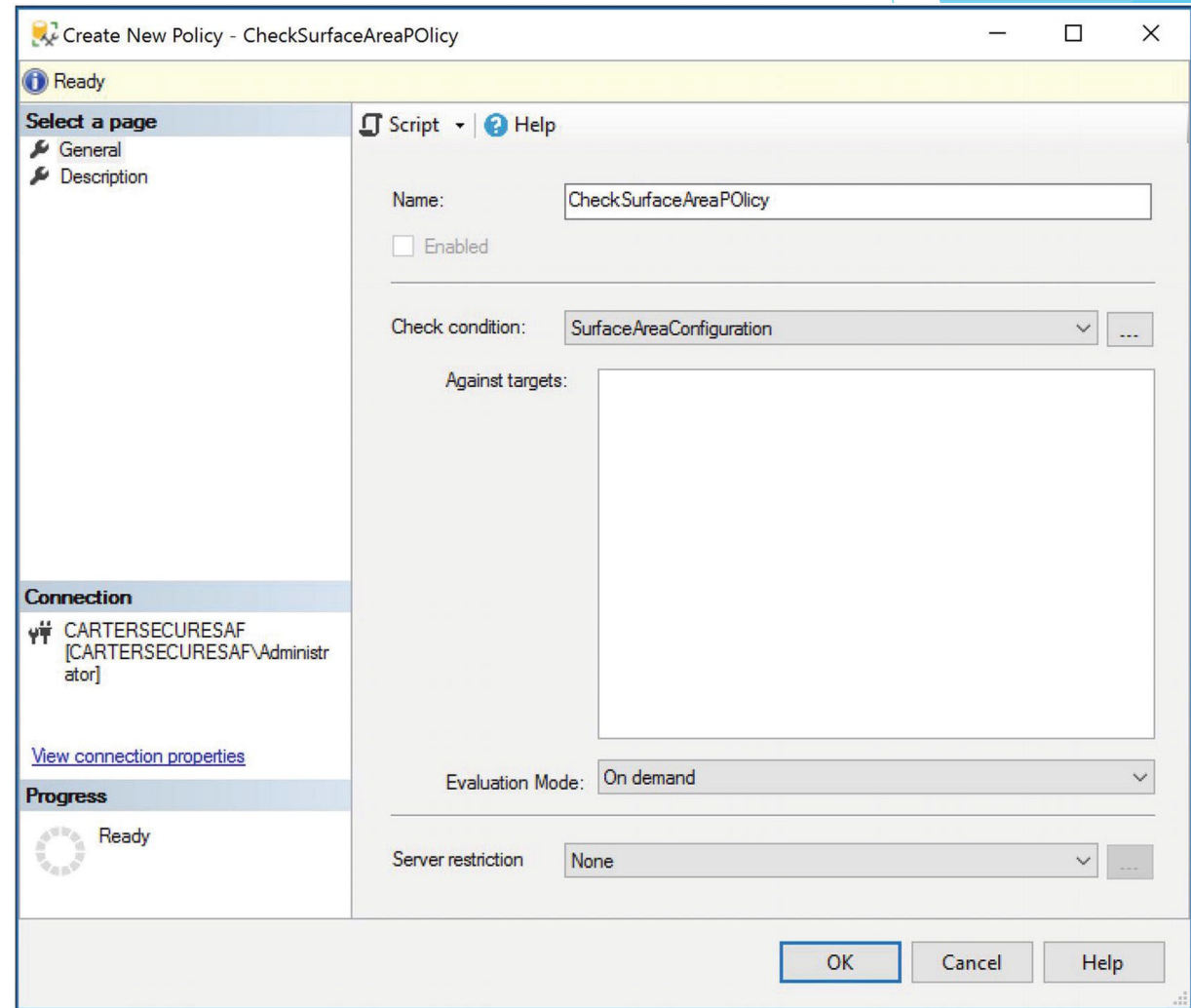


Figure 9-9 Create New Policy dialog box

Ensuring that Unsafe Features Remain Disabled

Evaluating the Policy Against a Single Instance (Cont)

- ▶ To evaluate against the instance created go to Management->Policy-Based Management->Policies and select Evaluate
- ▶ Evaluate Policies dialogbox as Figure 9-10 is shown.

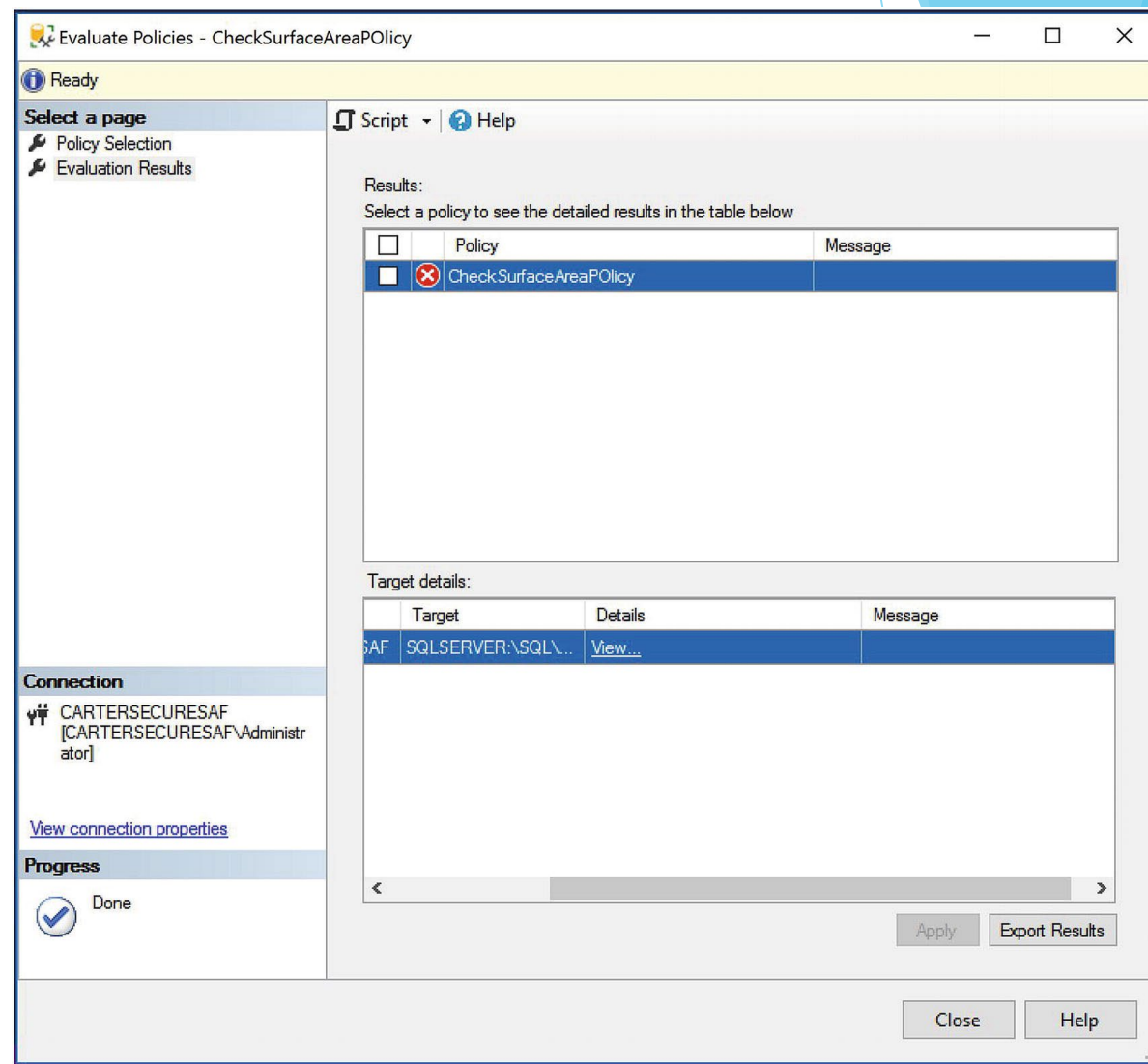


Figure 9-10 Evaluated Policies dialog box

Ensuring that Unsafe Features Remain Disabled

Evaluating the Policy Against a Single Instance

- ▶ Click View in the Details column will show the Results Detailed View dialog box as in Figure 9-11.
- ▶ This shows the status of each property evaluated.

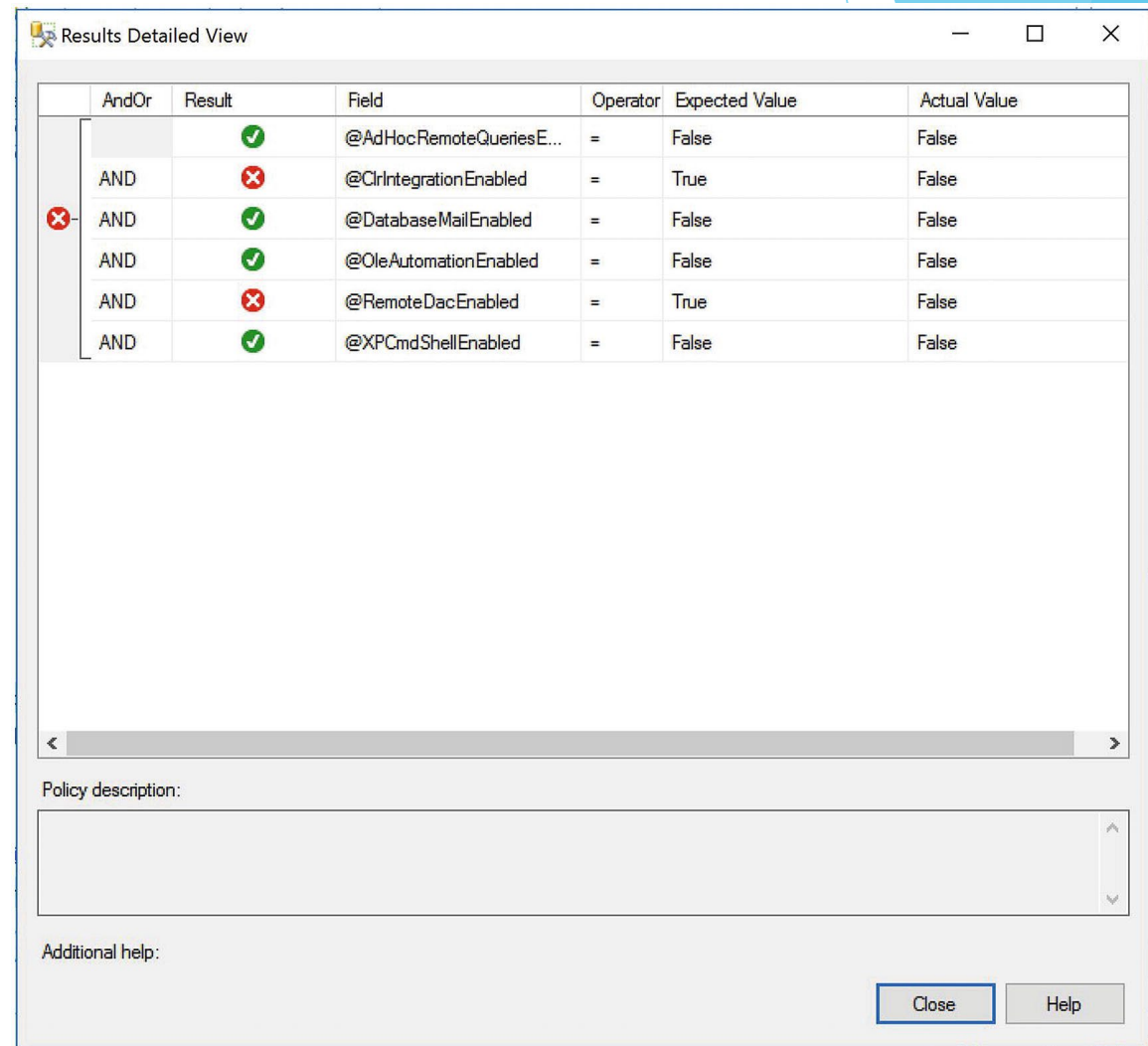


Figure 9-11 Results Detailed View dialog box



Ensuring that Unsafe Features Remain Disabled

Evaluating the Policy Against Multiple Instances

- ▶ Real benefit of PBM comes from ability to evaluate a policy against a large number of instances at the same time.
- ▶ Use a central management server configuration. Register an instance as a CMS and other instances as registered server.
- ▶ Once under a CMS, can run queries or evaluate policies against all servers managed by the CMS.
- ▶ Can also create server groups underneath CMS.
- ▶ Policies can also be evaluated against multiple instances using PowerShell.



Summary

- ▶ Reduce attack surface to make it harder for an attacker to successfully attack SQL Server Instances
- ▶ Understand the port requirements of SQL Server is key to implementing a secure firewall policy. Standardize with firewall engineers on required ports.
- ▶ Ensure unsecure features remain disabled unless specifically required and there is no workaround.